

Code Review Sheet

General Purpose | Code Quality & Security | April 11, 2026

■ Review Information

Project / Repo:

PR / Branch:

Reviewer: _____

Author: _____

Date: _____

Programming Language(s):

Review Type:

■ Code Quality

Criterion	What to Check	Rating
Readability	Variable/function/class names are clear and follow conventions. Code is self-explanatory without needing excessive comments.	■ Pass ■ Needs Work ■ Fail
Structure & Organisation	Logical file/module layout. Functions are single-purpose (SRP). No excessive nesting or god-classes.	■ Pass ■ Needs Work ■ Fail
DRY Principle	No unnecessary code duplication. Shared logic is extracted into helper functions or shared modules.	■ Pass ■ Needs Work ■ Fail
Comments & Documentation	Complex logic is explained with inline comments. Public APIs / functions have docstrings. No stale or misleading comments.	■ Pass ■ Needs Work ■ Fail
Error Handling	Errors and exceptions are caught and handled appropriately. Meaningful error messages are provided to the caller.	■ Pass ■ Needs Work ■ Fail
Code Complexity	Cyclomatic complexity is manageable. Long functions are broken into smaller, testable units.	■ Pass ■ Needs Work ■ Fail
Consistency	Coding style, formatting, and patterns match the existing codebase or agreed-upon linting rules (e.g. ESLint, Pylint, Checkstyle).	■ Pass ■ Needs Work ■ Fail
Logging & Observability	Key operations are logged at appropriate levels. Logs don't expose PII or secrets. Metrics / traces added where relevant.	■ Pass ■ Needs Work ■ Fail

Code Quality Notes

Code Review Sheet

General Purpose | Code Quality & Security | April 11, 2026

■ Security

Criterion	What to Check	Rating
Input Validation	All user-supplied data is validated and sanitised before use. Reject-by-default policy applied.	■ Pass ■ Needs Work ■ Fail
Injection Prevention	No raw SQL string concatenation. ORM / parameterised queries used. Shell commands sanitised against command injection.	■ Pass ■ Needs Work ■ Fail
Authentication & Authorisation	Endpoints / functions enforce auth checks. Roles and permissions are verified before sensitive operations.	■ Pass ■ Needs Work ■ Fail
Secrets Management	No hardcoded API keys, passwords, or tokens. Secrets are loaded from environment variables or a secrets manager.	■ Pass ■ Needs Work ■ Fail
Sensitive Data Handling	PII / sensitive data is encrypted at rest and in transit (TLS). Minimal data is collected / retained.	■ Pass ■ Needs Work ■ Fail
Error Message Safety	Error messages do not leak stack traces, file paths, or internal implementation details to end users.	■ Pass ■ Needs Work ■ Fail
Dependency Security	Third-party libraries are up to date. No known CVEs in pinned versions (checked via npm audit / pip-audit / OWASP).	■ Pass ■ Needs Work ■ Fail
Cryptography	Strong, industry-standard algorithms used (AES-256, SHA-256+). No home-rolled crypto or deprecated algorithms (MD5, SHA-1).	■ Pass ■ Needs Work ■ Fail

Security Notes

■ Summary & Verdict

Pass Count	Needs Work	Fail Count	Overall Score
_____ / 16	_____ / 16	_____ / 16	_____ %

Verdict

■ Approved	Code is ready to merge.
■ Approved w/ Comments	Minor issues – fix before merge.

Code Review Sheet

General Purpose | Code Quality & Security | April 11, 2026

■ Changes Required

Significant issues – revise & re-review.

Overall Comments & Action Items

Sign-off

Reviewer Signature:

Date:

Author Acknowledgement:

Date:

By signing, the author confirms they have read and understood the review feedback.